Web Security Vulnerability Assessment Report

Target: http://testfire.net
Tool Used: OWASP ZAP
Prepared By: Adithya Patel
Cybersecurity Internship Project March 2026

Executive Summary

A passive vulnerability assessment was conducted on the Altoro Mutual demo banking website to identify potential security weaknesses.

The security analysis was performed using OWASP ZAP, a widely used web application security testing tool. The scan identified several vulnerabilities including Cross-Site Scripting, SQL Injection risks, and missing security headers.

These issues demonstrate common security misconfigurations present in web applications and highlight the importance of secure coding and configuration practices.

Scope of Assessment

ITEM	DETAILS
Target Website	http://testfire.nett
Assessment Type	Passive Vulnerability Scan
Testing Scope	Public Pages Only
Testing Method	Automated Security Scan

Tools Used

TOOL	PURPOSE
OWASP ZAP	Web vulnerability scanning
Browser DevTools	Header analysis
Nmap	Network reconnaissance

Testing Methodology

[Target Identification]

↓

[Information Gathering]

↓

[Passive Vulnerability Scan]

↓

[Vulnerability Analysis]

↓

[Risk Classification]

↓

[Report Preparation]

Vulnerability Overview

Vulnerability	Severity
Cross-Site Scripting (XSS)	High
SQL Injection	High
Missing Security Headers	Medium
Cookie Security Issues	Medium
Information Disclosure	Low

Cross-Site Scripting (XSS)

Risk Level: High

- Cross-Site Scripting occurs when user input is reflected into web pages without proper sanitization. This allows attackers to inject malicious scripts that execute in the victim's browser.

Impact

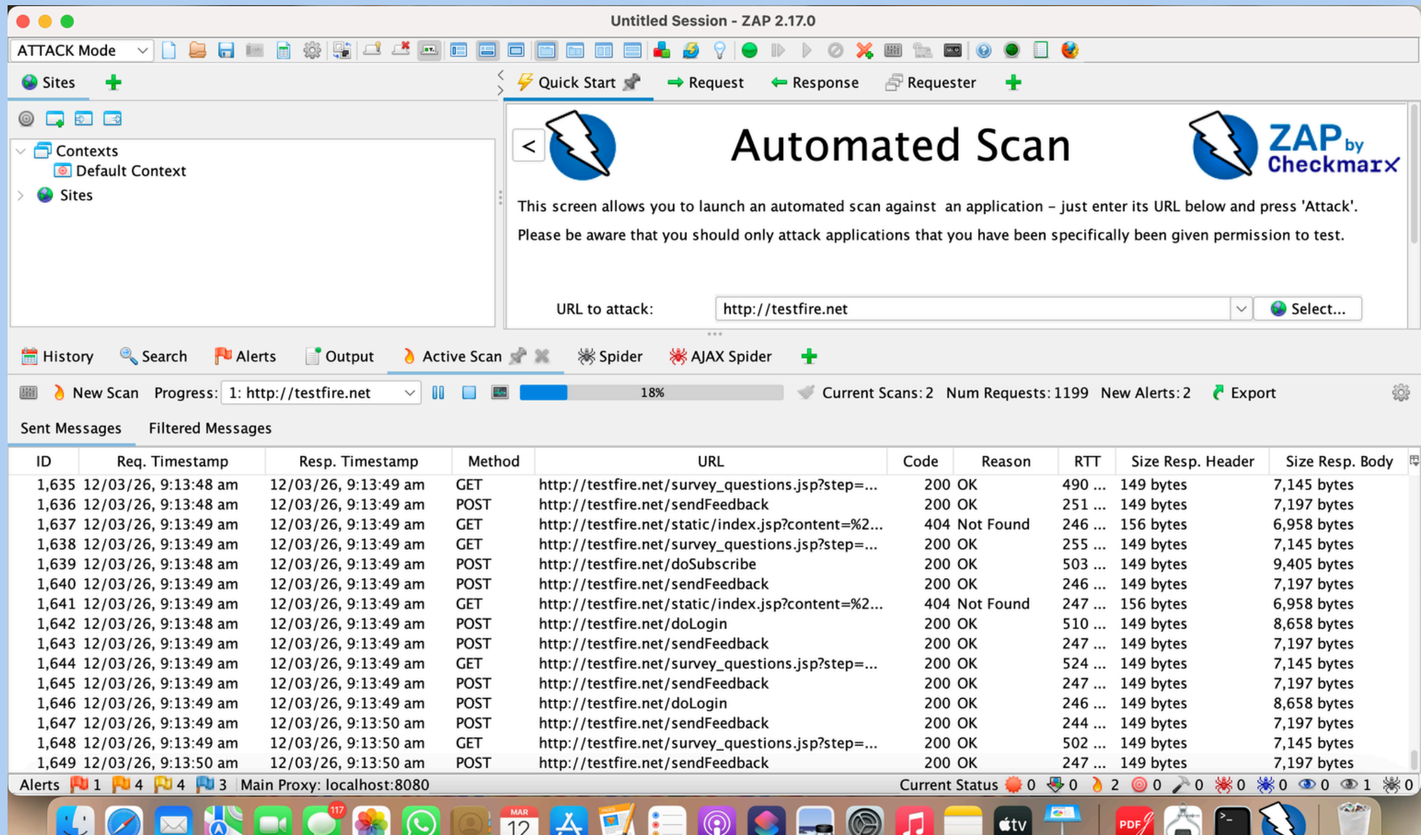
- Session hijacking
- Cookie theft
- Malicious script execution

Solution

Implement input validation

Encode user output

Deploy Content Security Policy



SQL Injection

Risk Level: High

SQL Injection vulnerabilities occur when user input is used in SQL queries without validation. Attackers may manipulate database queries to access or modify sensitive data.

Impact

- Data leakage
- Database compromise
- Unauthorized access

Solution

Use prepared statements
Validate input parameters
Apply secure database practices

Security Misconfiguration

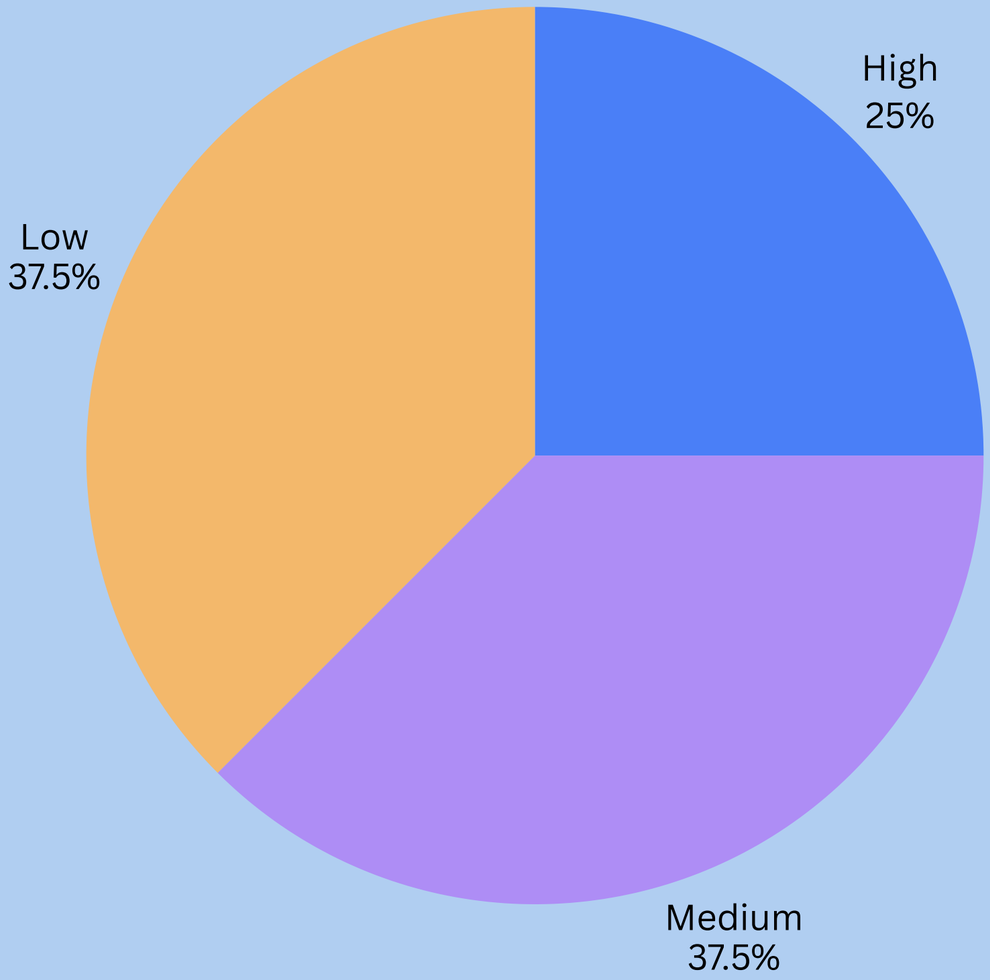
Issues Found:

- Missing Content-Security-Policy header
- Missing X-Frame-Options header
- Missing X-Content-Type-Options header
- Server version disclosure

Solution:

Implement recommended HTTP security headers

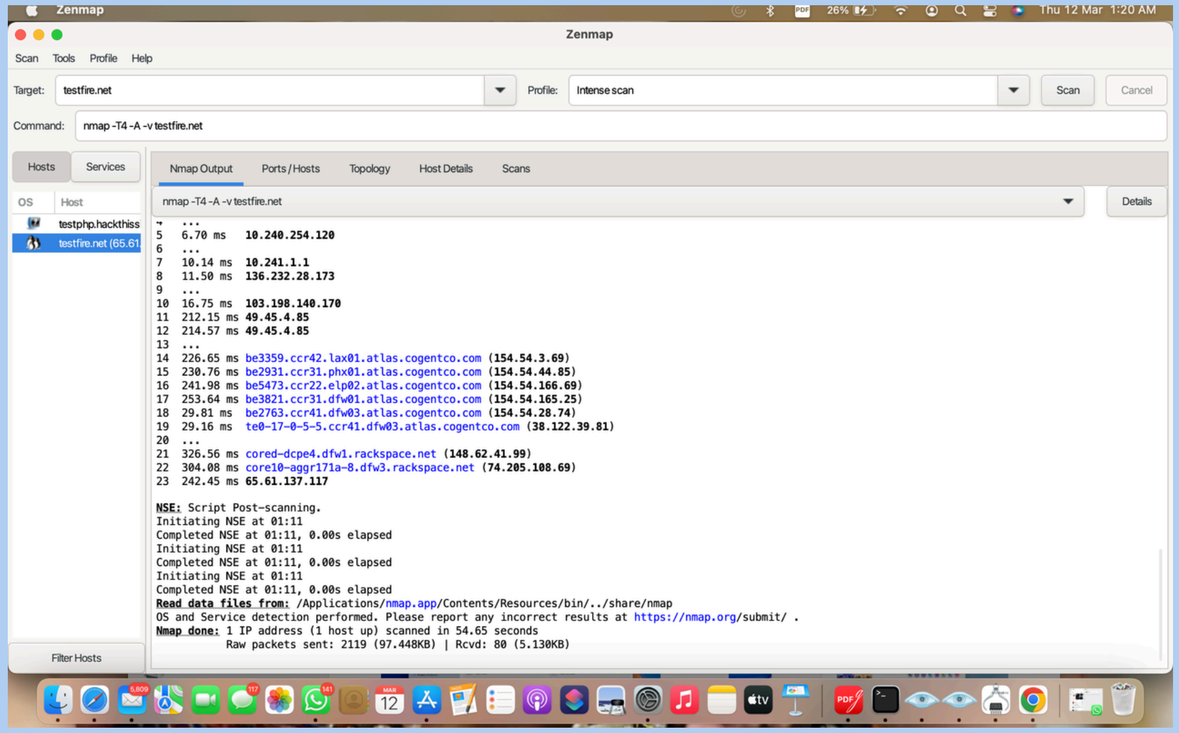
Scan Summary

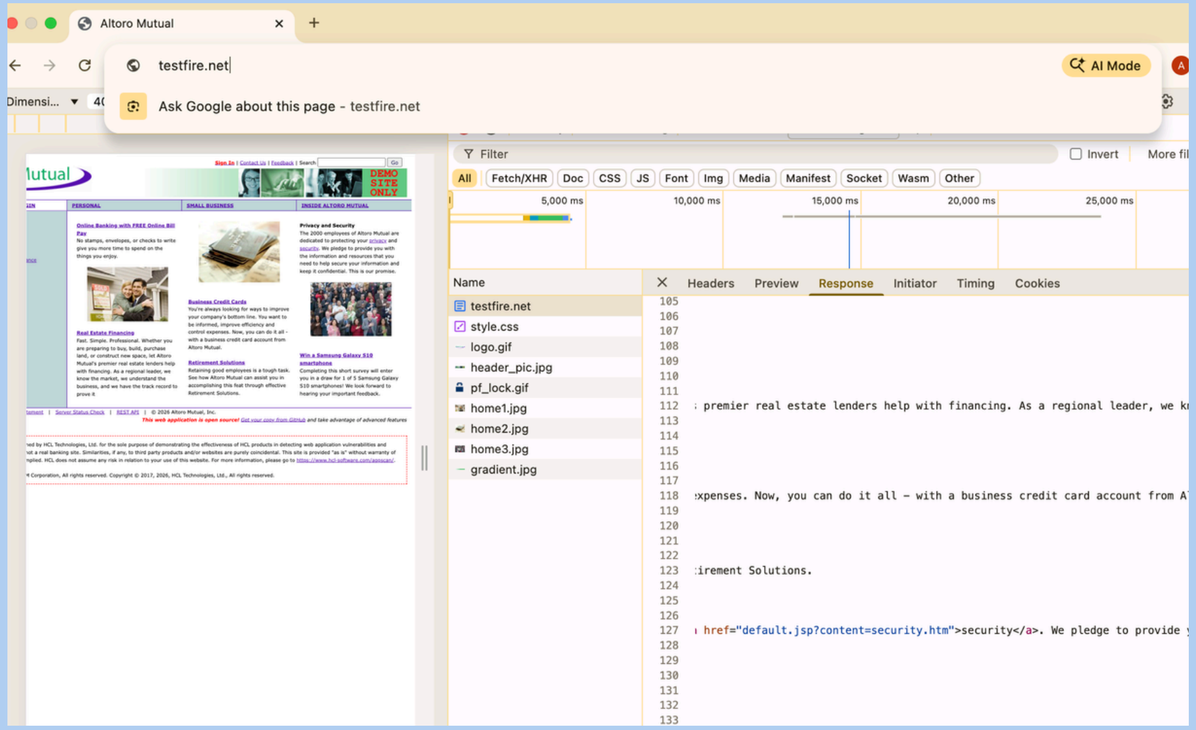


Security Recommendations

- ✓ Implement strong input validation
- ✓ Use prepared SQL queries
- ✓ Enable HTTP security headers
- ✓ Secure session cookies
- ✓ Conduct regular vulnerability assessments

Evidence


Zenmap
Scan Tools Profile Help
Target: testfire.net
Profile: Intense scan
Scan
Cancel
Command: nmap -T4 -A -v testfire.net
Hosts
Services
Nmap Output
Ports / Hosts
Topology
Host Details
Scans
nmap -T4 -A -v testfire.net
Details
OS Host
testphp.hackthiss
testfire.net (65.61
5 6.70 ms 10.240.254.120
7 10.14 ms 10.241.1.1
8 11.50 ms 136.232.28.173
10 16.75 ms 103.198.140.170
11 212.15 ms 49.45.4.85
12 214.57 ms 49.45.4.85
14 226.65 ms be3359.ccr42.lax01.atlas.cogentco.com (154.54.3.69)
15 230.76 ms be2931.ccr31.phx01.atlas.cogentco.com (154.54.44.85)
16 241.98 ms be5473.ccr22.elp02.atlas.cogentco.com (154.54.166.69)
17 253.64 ms be3821.ccr31.dfw01.atlas.cogentco.com (154.54.165.25)
18 29.81 ms be2763.ccr41.dfw03.atlas.cogentco.com (154.54.28.74)
19 29.16 ms te0-17-0-5-5.ccr41.dfw03.atlas.cogentco.com (38.122.39.81)
21 326.56 ms cored-dcpe4.dfw1.rackspace.net (148.62.41.99)
22 304.08 ms core10-aggr171a-8.dfw3.rackspace.net (74.205.108.69)
23 242.45 ms 65.61.137.117
NSE: Script Post-scanning.
Initiating NSE at 01:11
Completed NSE at 01:11, 0.00s elapsed
Initiating NSE at 01:11
Completed NSE at 01:11, 0.00s elapsed
Initiating NSE at 01:11
Completed NSE at 01:11, 0.00s elapsed
Read data files from: /Applications/nmap.app/Contents/Resources/bin/../share/nmap
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 54.65 seconds
Raw packets sent: 2119 (97.448KB) | Rcvd: 80 (5.130KB)
Filter Hosts


Altoro Mutual
testfire.net
AI Mode
Ask Google about this page - testfire.net
Filter
Invert
All Fetch/XHR Doc CSS JS Font Img Media Manifest Socket Wasm Other
5,000 ms 10,000 ms 15,000 ms 20,000 ms 25,000 ms
Name
Headers Preview Response Initiator Timing Cookies
testfire.net
style.css
logo.gif
header_pic.jpg
pf_lock.gif
home1.jpg
home2.jpg
home3.jpg
gradient.jpg
105
106
107
108
109
110
111
112 : premier real estate lenders help with financing. As a regional leader, we kn
113
114
115
116
117
118 xpenses. Now, you can do it all - with a business credit card account from A
119
120
121
122
123 irement Solutions.
124
125
126
127 href="default.jsp?content=security.htm">security</a>. We pledge to provide
128
129
130
131
132
133